HỌC VIỆN SÁNG TẠO KHỞI NGHIỆP TỪ CÔNG NGHỆ

BỘ 05 BÀI TẬP THỰC HÀNH NÂNG CAO – UBUNTU LINUX, MẠNG, VPN VÀ DOCKER

BÁO CÁO SỰ CỐ VÀ BÁO CÁO KỸ THUẬT

BÀI 4

ĐIỀU TRA TRUY CẬP SSH BẤT THƯỜNG VÀ XÂY DỰNG CƠ CHẾ CHẶN

Sinh viên	Trần Đức Việt Anh
Server	maychucuavietanh – Ubuntu 24.04.1 LTS, kernel 6.8.0-139-generic (x86_64)
Thời gian	Điều tra và triển khai ngày 11/09/2026 (UTC+7)

Hà Nội, tháng 09 năm 2026

1. Thông tin bài thực hành

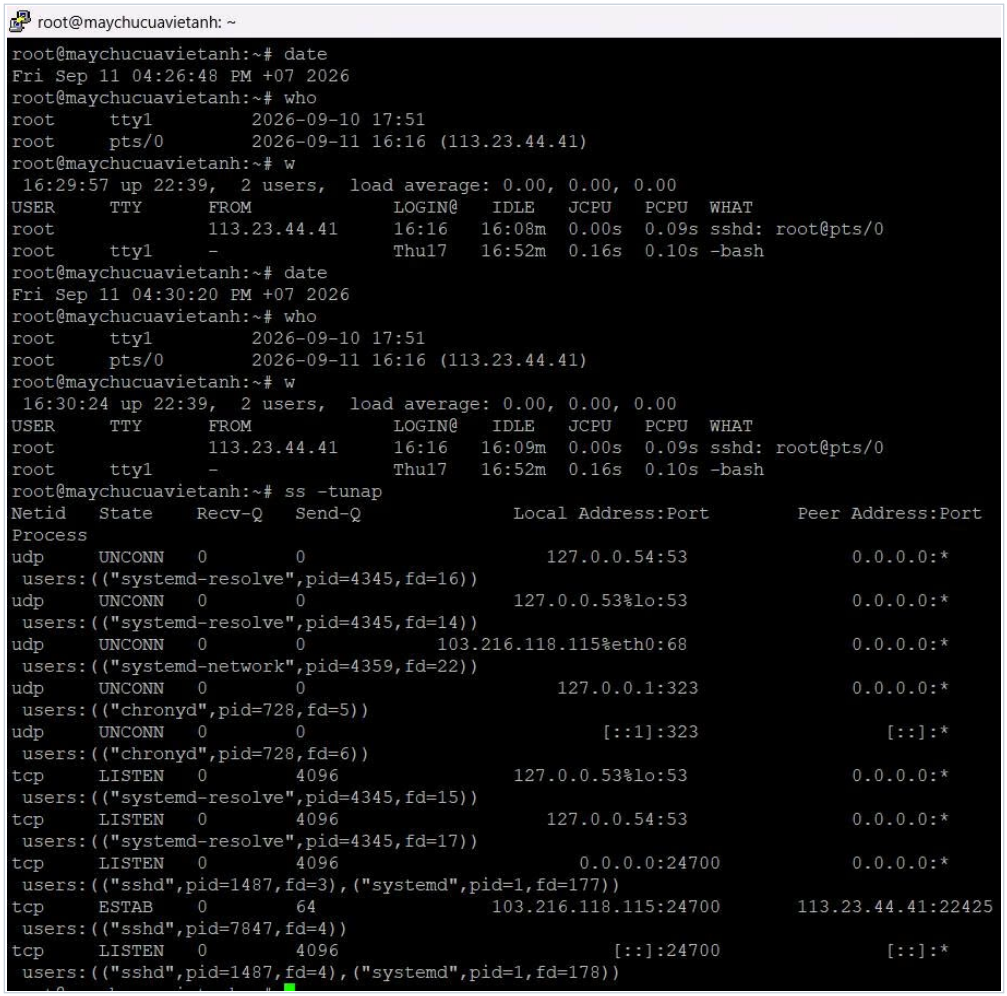
Hạng mục	Nội dung
Bài thực hành	Bài 4 – Điều tra truy cập SSH bất thường và xây dựng cơ chế chặn
Sinh viên	Trần Đức Việt Anh
Server	Hostname `maychucuavietanh`; Ubuntu 24.04.1 LTS; kernel 6.8.0-139-generic x86_64
Mạng	`eth0` 103.216.118.115 (IP công cộng); SSH nghe `0.0.0.0:24700` và `[::]:24700`
Thời gian	Bắt đầu điều tra 11/09/2026 16:26:48; triển khai và kiểm thử Fail2ban 21:20–21:36 cùng ngày
Phạm vi log	`/var/log/auth.log` hiện hành, `wtmp` (`last`), `btmp` (`lastb`), `/var/log/fail2ban.log`. Bản ghi sớm nhất trong ảnh chụp: 07/09/2026.
Kết luận nhanh	Có **một nguồn dò mật khẩu root kéo dài** (103.186.62.23), chưa thành công. Chưa phát hiện dấu hiệu xâm nhập ở mức kiểm tra cơ bản. Fail2ban đã chạy nhưng jail đang áp cho cổng 22 thay vì 24700 (S1).
Tình trạng hồ sơ	27/36 tiêu chí đạt, 2 không đạt, 7 chưa có minh chứng (`06_Checklist.txt`).

2. Hiện trạng ban đầu và yêu cầu cần đạt

Bộ phận giám sát phát hiện nhiều lần đăng nhập SSH thất bại và lưu lượng đến cổng SSH tăng bất thường. Nhiệm vụ gồm: bảo toàn bằng chứng, phân tích log để xác định nguồn đáng ngờ, kết luận có hay không có dấu hiệu xâm nhập, sau đó lập blacklist và triển khai cơ chế tự động chặn thử mật khẩu. Toàn bộ thao tác chỉ thực hiện ở góc độ phòng thủ trên server được cấp.

Trạng thái ghi nhận lúc bắt đầu điều tra (MC-01):

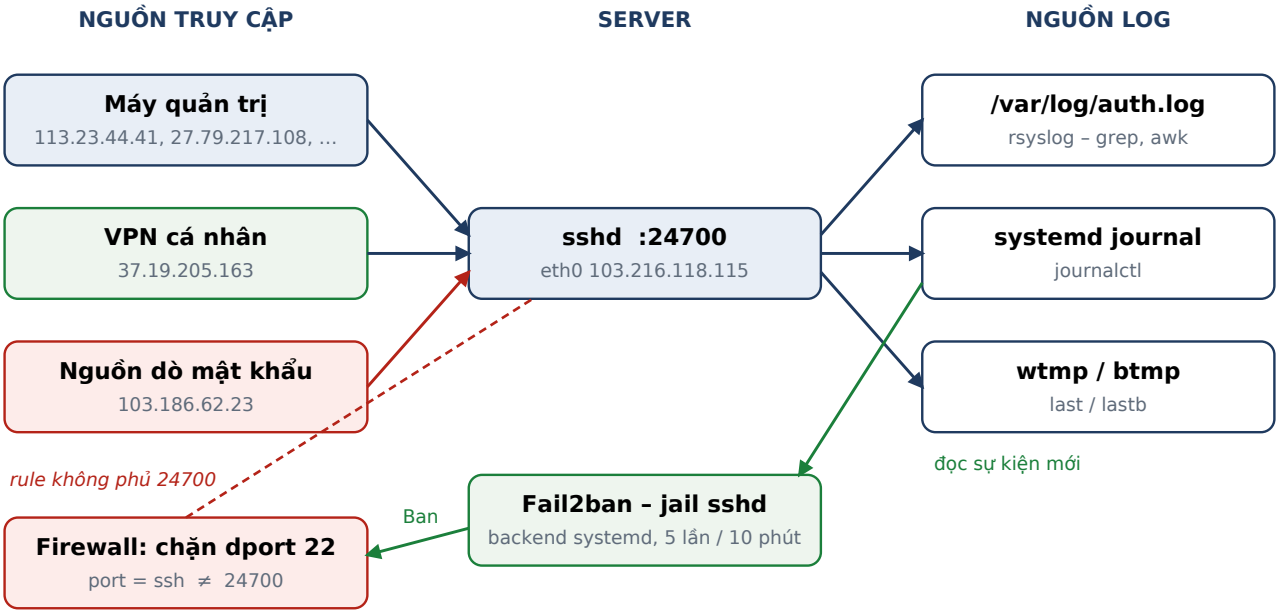
- Server chạy liên tục 22 giờ 39 phút (khởi động 10/09 lúc 17:50), tải bằng 0.
- Có 2 phiên root: phiên điều tra `pts/0` từ 113.23.44.41 (16:16) và một phiên trên console `tty1` mở từ 10/09 17:51, đã idle gần 17 giờ.
- Chỉ có một kết nối TCP ESTAB từ bên ngoài: `103.216.118.115:24700 ← 113.23.44.41:22425`, chính là phiên điều tra.
- Cổng mở ra ngoài duy nhất là 24700/tcp (SSH). Cổng 53 và 323 chỉ nghe trên loopback, còn 68/udp là DHCP client. Tiến trình `systemd` (PID 1) cùng giữ socket 24700 vì Ubuntu 24.04 kích hoạt SSH qua `ssh.socket`.



MC-01. date, who, w, ss -tunap lúc bắt đầu điều tra (16:26–16:30, 11/09/2026)

3. Sơ đồ luồng truy cập và nguồn log

Mọi luồng SSH đi vào `eth0` tới `sshd` ở cổng 24700. Mỗi lần xác thực được ghi đồng thời vào ba nơi: `auth.log` qua rsyslog, systemd journal, và `wtmp/btmp`. Fail2ban đọc journal, khi một IP vượt ngưỡng thì tạo rule chặn trên firewall theo tham số `port` của jail.



Nét đỏ: luồng đáng ngờ và điểm lệch cấu hình (Sự cố S1). Fail2ban đọc journal, không đọc lại lịch sử trong auth.log.

Hình 1. Luồng truy cập SSH, nguồn log và cơ chế chặn

4. Các bước điều tra và kết quả phân tích

4.1. Bảo toàn bằng chứng

Đề yêu cầu sao lưu log xác thực trước khi thay đổi firewall hoặc cài công cụ bảo vệ. Hồ sơ hiện **chưa có minh chứng** cho bước này. Phân tích ở các mục sau chạy trực tiếp trên log đang được ghi, nên chịu ảnh hưởng của Sự cố S3. Quy trình cần bổ sung:

```
mkdir -p ~/bai4_evidence
sudo cp -p /var/log/auth.log* /var/log/btmp* /var/log/wtmp ~/bai4_evidence/
sudo journalctl -u ssh --no-pager > ~/bai4_evidence/journal_ssh.txt
sha256sum ~/bai4_evidence/* > ~/bai4_evidence/SHA256SUMS   # chứng minh bản sao không bị sửa
```

4.2. Thống kê đăng nhập thất bại theo IP

Lần đầu dùng `awk '{print $(NF-3)}'` (MC-02), tức lấy trường thứ tư tính từ cuối dòng, đúng vị trí IP trong `Failed password for root from <IP> port <N> ssh2`. Kết quả lẫn một dòng `COMMAND=/usr/bin/grep`, là chính lệnh sudo của người điều tra (Sự cố S3). Lần hai dùng `grep -oP 'from \K[0-9\.]+'` (MC-08), chỉ lấy chuỗi số sau từ `from`, nên loại được dòng nhiễm. `auth.log` hiện hành chỉ có 7 nguồn thất bại; bảng dưới là toàn bộ, kèm đối chiếu với `btmp` và các lần thành công.

#	IP nguồn	Failed	lastb	Accepted	Phiên last	Hình thái
1	**103.186.62.23**	**33**	31	chưa đếm	**0**	1 lần mỗi lượt, cách nhau 22 phút–3 giờ, cả ban đêm, 08/09–11/09
2	14.0.22.154	16	24	13	10	Cụm 1–2 phút, thành công ngay sau
3	37.19.205.163	6	8	chưa đếm	3	Cụm 23:30–23:31 10/09, thành công 23:32
4	146.70.192.172	6	7	1	ngoài ảnh	Cụm 15:35–15:37 07/09
5	1.52.236.115	4	5	2	2	Cụm 20:42 10/09, thành công 20:43
6	113.23.44.41	4	5	7	6	Cụm 12:21 11/09, thành công 12:23
7	27.79.217.108	2	3	9	9	Gõ sai 21:35 10/09 và 12:28 11/09, thành công ngay sau

Failed: số dòng `Failed password` trong auth.log; Accepted: số dòng Accepted trong auth.log; Phiên last: số phiên trong ảnh MC-04.
Số của `lastb` thường cao hơn `Failed password` vì `btmp` ghi mọi lần xác thực hỏng, kể cả các lần không sinh dòng `Failed password`. 103.186.62.23 tăng từ 31 (MC-02) lên 33 (MC-08) giữa hai lần chạy, phù hợp với việc nguồn này vẫn tiếp tục thử trong lúc điều tra (`lastb` ghi nhận lúc 16:33).

```
root@maychucuavietanh:/var/log# sudo grep "Failed password" /var/log/auth.log \
| awk '{print $(NF-3)}' \
| sort \
| uniq -c \
| sort -nr \
| head -10
     31 103.186.62.23
     16 14.0.22.154
      6 37.19.205.163
      6 146.70.192.172
      4 1.52.236.115
      4 113.23.44.41
      2 COMMAND=/usr/bin/grep
      2 27.79.217.108
```

MC-02. Thống kê bằng awk: có dòng nhiễm COMMAND=/usr/bin/grep

```
root@maychucuavietanh:~# grep "Failed password" /var/log/auth.log | grep -oP 'from \K[0-9\.]+' | sort | uniq -c | sort -nr | head -n 10
     33 103.186.62.23
     16 14.0.22.154
      6 37.19.205.163
      6 146.70.192.172
      4 1.52.236.115
      4 113.23.44.41
      2 27.79.217.108
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# grep "Accept" /var/log/auth.log | grep -oP '14.0.22.154' | sort | uniq -c | sort -nr | head -n 10
     13 14.0.22.154
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# grep "Accept" /var/log/auth.log | grep -oP ' 1.52.236.115' | sort | uniq -c | sort -nr | head -n 10
      2  1.52.236.115
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# grep "Accept" /var/log/auth.log | grep -oP '27.79.217.108' | sort | uniq -c | sort -nr | head -n 10
      9 27.79.217.108
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# grep "Accept" /var/log/auth.log | grep -oP '146.70.192.172' | sort | uniq -c | sort -nr | head -n 10
      1 146.70.192.172
root@maychucuavietanh:~# ^C
root@maychucuavietanh:~# grep "Accept" /var/log/auth.log | grep -oP '113.23.44.41' | sort | uniq -c | sort -nr | head -n 10
      7 113.23.44.41
```

MC-08. Thống kê bằng regex sau 'from' và đối chiếu số lần Accepted

4.3. Username bị thử

Truy vấn `grep -oP 'invalid user \K\S+'` (MC-03) trả về `5 \\K\\S+'`. Đây không phải username mà là 5 dòng sudo ghi lại chính câu lệnh grep, nên kết quả không dùng được (S3). Thống kê username vì vậy lấy từ `lastb` (MC-05, MC-06, 90 bản ghi):

Username	Số lần	Tồn tại?	Ghi chú
`root`	82 qua SSH, 4 trên tty1	Có	Mục tiêu duy nhất của 103.186.62.23 (31/31 bản ghi)
`deployer`	1 qua SSH	Có	27.79.217.108 lúc 12:28 11/09; đăng nhập thành công ngay sau (Bài 3)
`UNKNOWN`	3 trên tty1	Không	`login` che tên đăng nhập không hợp lệ để tránh lưu mật khẩu gõ nhầm vào ô username; console 10/09 17:40–17:41

Trong phạm vi ảnh, không có username không tồn tại nào được thử qua SSH. Việc kiểm tra trên `auth.log` cần chạy lại, có lọc theo tiến trình sshd (mục 7.4).

```
root@maychucuavietanh:/var/log# sudo grep -oP 'invalid user \K\S+' /var/log/auth.log | sort | uniq -c | sort -r | head -n 2
      5 \\K\\S+'
```

MC-03. Truy vấn username bị nhiễm bởi log của chính lệnh sudo

```
root@maychucuavietanh:~# lastb
root     ssh:notty    103.186.62.23    Fri Sep 11 16:33 - 16:33  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 14:08 - 14:08  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 12:51 - 12:51  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 12:28 - 12:28  (00:00)
deployer ssh:notty    27.79.217.108    Fri Sep 11 12:28 - 12:28  (00:00)
root     ssh:notty    113.23.44.41     Fri Sep 11 12:21 - 12:21  (00:00)
root     ssh:notty    113.23.44.41     Fri Sep 11 12:21 - 12:21  (00:00)
root     ssh:notty    113.23.44.41     Fri Sep 11 12:21 - 12:21  (00:00)
root     ssh:notty    113.23.44.41     Fri Sep 11 12:21 - 12:21  (00:00)
root     ssh:notty    113.23.44.41     Fri Sep 11 12:21 - 12:21  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 10:37 - 10:37  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 09:23 - 09:23  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 07:52 - 07:52  (00:00)
root     ssh:notty    14.0.22.154      Fri Sep 11 07:15 - 07:15  (00:00)
root     ssh:notty    14.0.22.154      Fri Sep 11 07:14 - 07:14  (00:00)
root     ssh:notty    14.0.22.154      Fri Sep 11 07:14 - 07:14  (00:00)
root     ssh:notty    14.0.22.154      Fri Sep 11 07:14 - 07:14  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 06:19 - 06:19  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 05:19 - 05:19  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 03:02 - 03:02  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 02:15 - 02:15  (00:00)
root     ssh:notty    103.186.62.23    Fri Sep 11 00:37 - 00:37  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:31 - 23:31  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:31 - 23:31  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:31 - 23:31  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:30 - 23:30  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:30 - 23:30  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:30 - 23:30  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:30 - 23:30  (00:00)
root     ssh:notty    37.19.205.163    Thu Sep 10 23:30 - 23:30  (00:00)
root     ssh:notty    103.186.62.23    Thu Sep 10 21:43 - 21:43  (00:00)
root     ssh:notty    27.79.217.108    Thu Sep 10 21:35 - 21:35  (00:00)
root     ssh:notty    27.79.217.108    Thu Sep 10 21:35 - 21:35  (00:00)
root     ssh:notty    1.52.236.115     Thu Sep 10 20:42 - 20:42  (00:00)
root     ssh:notty    1.52.236.115     Thu Sep 10 20:42 - 20:42  (00:00)
root     ssh:notty    1.52.236.115     Thu Sep 10 20:42 - 20:42  (00:00)
root     ssh:notty    1.52.236.115     Thu Sep 10 20:42 - 20:42  (00:00)
root     ssh:notty    1.52.236.115     Thu Sep 10 20:42 - 20:42  (00:00)
root     ssh:notty    103.186.62.23    Thu Sep 10 20:00 - 20:00  (00:00)
root     ssh:notty    103.186.62.23    Thu Sep 10 18:21 - 18:21  (00:00)
root     tty1                          Thu Sep 10 17:43 - 17:43  (00:00)
UNKNOWN  tty1                          Thu Sep 10 17:41 - 17:41  (00:00)
UNKNOWN  tty1                          Thu Sep 10 17:41 - 17:41  (00:00)
root     tty1                          Thu Sep 10 17:41 - 17:41  (00:00)
root     tty1                          Thu Sep 10 17:40 - 17:40  (00:00)
UNKNOWN  tty1                          Thu Sep 10 17:40 - 17:40  (00:00)
root     tty1                          Thu Sep 10 17:40 - 17:40  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 14:26 - 14:26  (00:00)
```

```
root     ssh:notty    103.186.62.23    Wed Sep  9 13:00 - 13:00  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 11:24 - 11:24  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 10:55 - 10:55  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 10:55 - 10:55  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 10:55 - 10:55  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 10:55 - 10:55  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 10:41 - 10:41  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 08:43 - 08:43  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 08:11 - 08:11  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 08:10 - 08:10  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 08:10 - 08:10  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 08:10 - 08:10  (00:00)
root     ssh:notty    14.0.22.154      Wed Sep  9 08:10 - 08:10  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 07:20 - 07:20  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 05:26 - 05:26  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 05:04 - 05:04  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 02:54 - 02:54  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 01:22 - 01:22  (00:00)
root     ssh:notty    103.186.62.23    Wed Sep  9 00:25 - 00:25  (00:00)
root     ssh:notty    103.186.62.23    Tue Sep  8 21:09 - 21:09  (00:00)
root     ssh:notty    103.186.62.23    Tue Sep  8 19:49 - 19:49  (00:00)
root     ssh:notty    103.186.62.23    Tue Sep  8 16:40 - 16:40  (00:00)
root     ssh:notty    14.0.22.154      Tue Sep  8 15:03 - 15:03  (00:00)
root     ssh:notty    14.0.22.154      Tue Sep  8 15:03 - 15:03  (00:00)
root     ssh:notty    14.0.22.154      Tue Sep  8 15:02 - 15:02  (00:00)
root     ssh:notty    103.186.62.23    Tue Sep  8 13:56 - 13:56  (00:00)
root     ssh:notty    103.186.62.23    Tue Sep  8 11:37 - 11:37  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:37 - 15:37  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:37 - 15:37  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:37 - 15:37  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:36 - 15:36  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:35 - 15:35  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:35 - 15:35  (00:00)
root     ssh:notty    146.70.192.172   Mon Sep  7 15:35 - 15:35  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:57 - 13:57  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:57 - 13:57  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:56 - 13:56  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:56 - 13:56  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:56 - 13:56  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:56 - 13:56  (00:00)
root     ssh:notty    14.0.22.154      Mon Sep  7 13:18 - 13:18  (00:00)
```

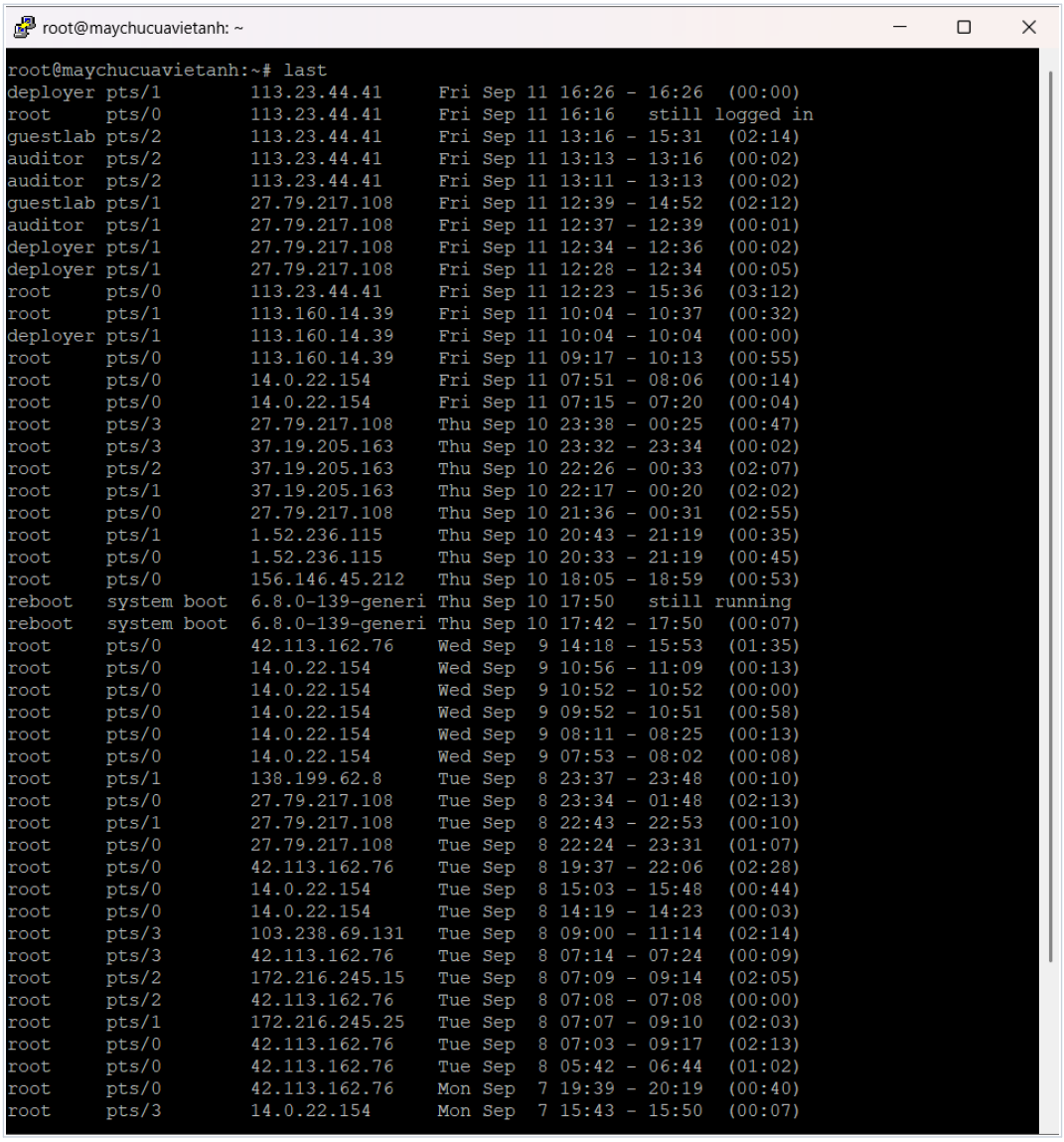
MC-05 (trái) và MC-06 (phải). lastb: 90 bản ghi thất bại từ 07/09 13:18 đến 11/09 16:33; bản text ở 04_Log/05_lastb_dang_nhap_that_bai.txt

4.4. Đăng nhập thành công và đối chiếu nguồn

`last` (MC-04) ghi nhận 45 phiên thành công từ 12 IP, cộng thêm 146.70.192.172 có 1 lần Accepted nằm ngoài phạm vi ảnh. **Không có phiên nào từ 103.186.62.23.** Bảng dưới đối chiếu từng nguồn với căn cứ xác định chủ sở hữu:

IP	Phiên	Tài khoản	Thời gian	Căn cứ
113.23.44.41	6	root, deployer, auditor, guestlab	11/09 12:23–16:26	Phiên điều tra hiện tại (MC-01)
27.79.217.108	9	root, deployer, auditor, guestlab	08/09–11/09	Máy dùng để kiểm thử Bài 3
113.160.14.39	3	root, deployer	11/09 09:17–10:37	Trùng lúc cấu hình Bài 3
14.0.22.154	10	root	07/09–11/09	Sinh viên xác nhận
37.19.205.163	3	root	10/09 22:17–23:34	Sinh viên xác nhận: VPN cá nhân
1.52.236.115	2	root	10/09 20:33–21:19	Sinh viên xác nhận
146.70.192.172	1*	–	07/09	Sinh viên xác nhận
42.113.162.76	7	root	07/09–09/09	**Chưa xác nhận**
172.216.245.15 / .25	1 + 1	root	08/09 07:07–09:14	**Chưa xác nhận**
103.238.69.131	1	root	08/09 09:00–11:14	**Chưa xác nhận**
156.146.45.212	1	root	10/09 18:05–18:59	**Chưa xác nhận**
138.199.62.8	1	root	08/09 23:37–23:48	**Chưa xác nhận**

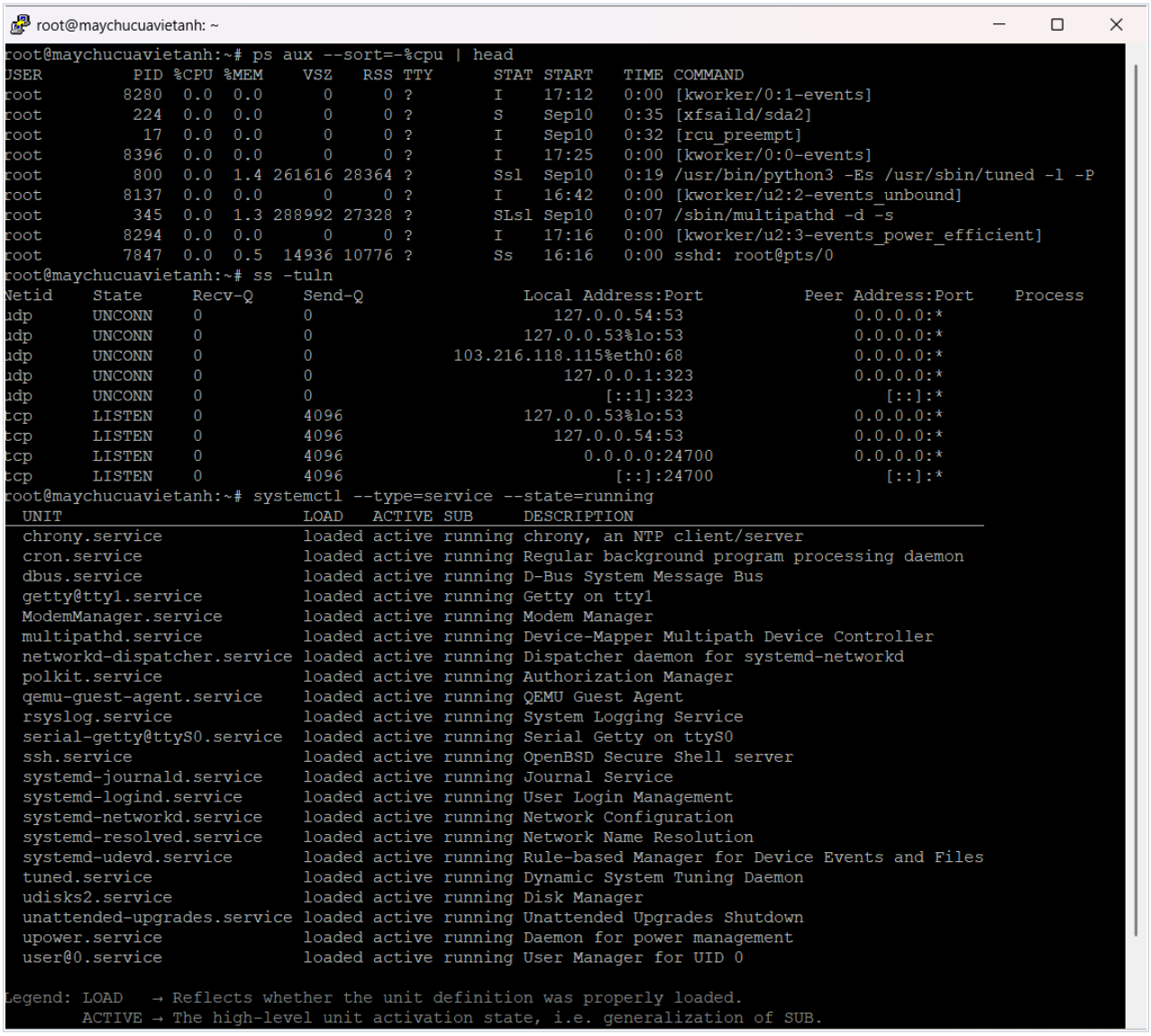
* Theo số Accepted trong auth.log (MC-08). Đáng chú ý: sáng 08/09 từ 07:03 đến 09:17 có tới 4 phiên root song song từ 4 IP khác nhau (42.113.162.76, 172.216.245.25, 172.216.245.15, và 103.238.69.131 từ 09:00). Cần xác nhận người sử dụng trước khi kết luận.



MC-04. last: phiên thành công và 2 lần khởi động lại ngày 10/09

4.5. Tiến trình, cổng và service

MC-07 không cho thấy dấu hiệu bất thường ở mức cơ bản. `ps aux --sort=-%cpu` chỉ có kernel thread, `tuned`, `multipathd` và phiên sshd của người điều tra. `ss -tuln` không có cổng nghe lạ. 22 service đang chạy đều là thành phần chuẩn của Ubuntu cloud image. Một số service không cần trên server (`ModemManager`, `udisks2`, `upower`) được đưa vào đề xuất. `cron.service` đang chạy nhưng **nội dung crontab chưa được kiểm tra**, mà cron là nơi thường bị cài cơ chế bám trụ sau xâm nhập.



MC-07. ps aux, ss -tuln, systemctl --type=service --state=running

4.6. Phân loại nguồn truy cập

Phân loại	Nguồn	Căn cứ log
Hợp lệ	113.23.44.41, 27.79.217.108, 113.160.14.39	Gắn trực tiếp với các phiên làm bài (MC-01, MC-04).
Hợp lệ (SV xác nhận)	14.0.22.154, 37.19.205.163, 1.52.236.115, 146.70.192.172	Thất bại theo cụm trong 1–2 phút rồi thành công ngay sau: hình thái gõ sai mật khẩu.
Chưa xác định	42.113.162.76, 172.216.245.15, 172.216.245.25, 172.216.245.31, 103.238.69.131, 156.146.45.212, 138.199.62.8; hoạt động console tty1 10/09 17:40–17:51	Có phiên root thành công hoặc bị Fail2ban ban (172.216.245.31) nhưng chưa xác định người dùng.
Nghi ngờ – phải chặn	**103.186.62.23**	Xem lý do bên dưới.

Lý do xếp 103.186.62.23 vào nhóm phải chặn:

- Nhiều thất bại nhất (33 dòng Failed password, 31 bản ghi btmp) và **không có phiên thành công nào** trong wtmp suốt thời gian thử.

- 100% nhắm vào `root`.
- Nhịp thử đều, mỗi lượt đúng 1 lần, kéo dài từ 08/09 11:37 tới 11/09 21:35, kể cả khung 00:25–05:26. Người gõ nhầm tạo cụm thất bại rồi thành công (như 6 IP còn lại); đây là hình thái công cụ tự động dò mật khẩu chậm (low-and-slow).
- Vẫn tiếp diễn trong lúc điều tra (16:33) và sau khi Fail2ban hoạt động (21:35:49, MC-10).

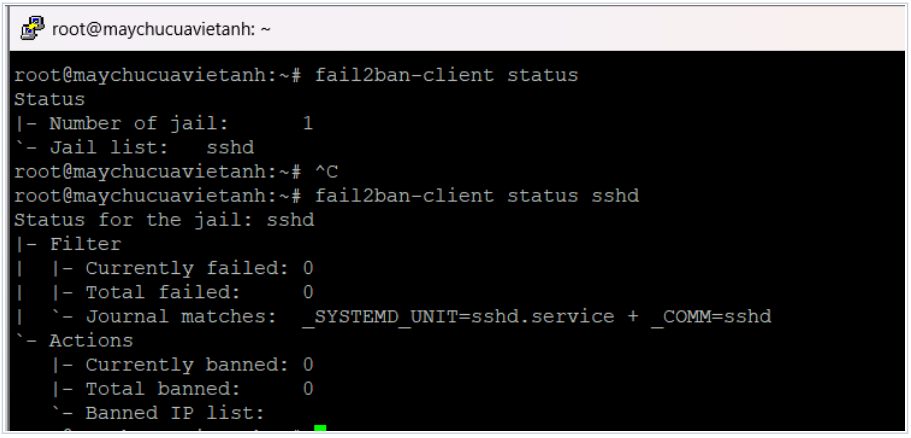
4.7. Triển khai Fail2ban

```
# /etc/fail2ban/jail.local  (bản sao ở 03_Cau_hinh/jail.local)
[sshd]
enabled = true
port = ssh
backend = systemd
maxretry = 5
findtime = 10m
bantime = 10m
```

Cấu hình đặt trong `jail.local` để không bị ghi đè khi cập nhật gói (`jail.conf` là file gốc). `backend = systemd` cho phép Fail2ban đọc journal thay vì file. Ý nghĩa: một IP thất bại `maxretry = 5` lần trong cửa sổ `findtime = 10m` sẽ bị chặn `bantime = 10m`. Thời gian cấm ngắn phù hợp môi trường lab vì người làm bài có thể tự ban mình.

Ngay sau khi cài (MC-09), jail báo `Total failed: 0` dù log có hơn 70 lần thất bại. Lý do là backend systemd chỉ xử lý bản ghi **mới** kể từ khi jail khởi động (MC-10: `process new journal entries`), không quét lại lịch sử. Điều kiện `_SYSTEMD_UNIT=sshd.service + _COMM=sshd` là phép OR. Trên Ubuntu 24.04 unit tên là `ssh.service`, nhưng điều kiện `_COMM=sshd` vẫn bắt được sự kiện.

Điểm lệch quan trọng: `port = ssh` được tra trong `/etc/services` thành cổng 22, trong khi SSH chạy ở 24700. Chi tiết ở Sự cố S1.



MC-09. Trạng thái Fail2ban ngay sau khi cài

4.8. Timeline sự kiện

Thời điểm (UTC+7)	Sự kiện	Nguồn
07/09 13:18	Bản ghi thất bại sớm nhất trong phạm vi ảnh (14.0.22.154)	lastb
07/09 15:35–15:37	146.70.192.172: 7 lần thất bại	lastb
08/09 07:03–09:17	4 phiên root song song từ 4 IP chưa xác nhận	last
08/09 11:37	103.186.62.23 bắt đầu thử root (lần đầu trong phạm vi ảnh)	lastb
09/09 00:25–14:26	103.186.62.23: 11 lần, gồm cả rạng sáng	lastb
10/09 17:40–17:51	7 lần thất bại trên console tty1; khởi động lại 17:42 và 17:50; phiên root tty1 bắt đầu 17:51	lastb, last, who
10/09 20:42 và 23:30	1.52.236.115 và 37.19.205.163 gõ sai theo cụm rồi thành công	lastb, last
11/09 00:37–14:08	103.186.62.23: 11 lần	lastb
11/09 16:16	Bắt đầu phiên điều tra (root từ 113.23.44.41)	who, last
11/09 16:26:48	Ghi nhận hiện trạng	MC-01
11/09 16:33	103.186.62.23 tiếp tục thử trong lúc điều tra	lastb
Trước 21:20	Cài Fail2ban (0 failed, 0 banned); 172.216.245.31 bị ban	MC-09, MC-10
21:20:15–21:20:21	Jail sshd khởi động lại, khôi phục ban 172.216.245.31	MC-10
21:22:29–21:25:34	5 lần thất bại từ 113.23.44.41 (kiểm thử) → Ban	MC-10
21:35:35	Unban 113.23.44.41 sau đúng 10 phút	MC-10
21:35:49	103.186.62.23 tiếp tục thử, không đạt ngưỡng, không bị ban	MC-10

5. Kết quả kiểm thử

5.1. Kiểm thử ban / unban

Từ 21:22:29 đến 21:25:34, IP 113.23.44.41 có 5 lần thất bại trong khoảng 3 phút, dưới `findtime` 10 phút. Lần thứ 5 đạt `maxretry` và bị ban lúc 21:25:34. Lệnh unban chạy lúc 21:35:35, đúng `bantime` 10 phút. Như vậy logic phát hiện và đếm ngưỡng hoạt động đúng. Tuy nhiên, log `Ban` chỉ chứng minh Fail2ban đã ra lệnh chặn, **chưa chứng minh kết nối tới 24700 bị chặn thật** (S1).

```
root@maychucuavietanh:~# tail -f /var/log/fail2ban.log
2026-09-11 21:20:15,599 fail2ban.filtersystemd  [9910]: INFO    [sshd] Jail is in operation now (process new journal entries)
2026-09-11 21:20:20,863 fail2ban.jail           [9910]: INFO    Jail 'sshd' started
2026-09-11 21:20:21,601 fail2ban.actions        [9910]: NOTICE  [sshd] Restore Ban 172.216.245.31
2026-09-11 21:22:29,900 fail2ban.filter         [9910]: INFO    [sshd] Found 113.23.44.41 - 2026-09-11 21:22:29
2026-09-11 21:23:00,294 fail2ban.actions        [9910]: NOTICE  [sshd] Unban 172.216.245.31
2026-09-11 21:25:03,855 fail2ban.filter         [9910]: INFO    [sshd] Found 113.23.44.41 - 2026-09-11 21:25:03
2026-09-11 21:25:12,399 fail2ban.filter         [9910]: INFO    [sshd] Found 113.23.44.41 - 2026-09-11 21:25:11
2026-09-11 21:25:22,604 fail2ban.filter         [9910]: INFO    [sshd] Found 113.23.44.41 - 2026-09-11 21:25:22
2026-09-11 21:25:34,900 fail2ban.filter         [9910]: INFO    [sshd] Found 113.23.44.41 - 2026-09-11 21:25:34
2026-09-11 21:25:34,964 fail2ban.actions        [9910]: NOTICE  [sshd] Ban 113.23.44.41
2026-09-11 21:35:35,196 fail2ban.actions        [9910]: NOTICE  [sshd] Unban 113.23.44.41
2026-09-11 21:35:50,266 fail2ban.filter         [9910]: INFO    [sshd] Found 103.186.62.23 - 2026-09-11 21:35:49
```

MC-10. fail2ban.log: khởi động lại jail, Restore Ban, Found, Ban, Unban

5.2. Duy trì sau khởi động lại

Jail `sshd` khởi động lại lúc 21:20:15 và ngay sau đó `Restore Ban 172.216.245.31`: một lệnh ban có từ trước được khôi phục từ cơ sở dữ liệu của Fail2ban rồi gỡ khi hết hạn lúc 21:23:00. Điều này chứng minh trạng thái ban được giữ qua lần khởi động lại service. Hồ sơ chưa có minh chứng sau reboot server và `systemctl is-enabled fail2ban`.

5.3. Nguồn dò chậm vượt qua ngưỡng Fail2ban

Khoảng cách ngắn nhất giữa hai lần thử của 103.186.62.23 là 22 phút, nên mọi cửa sổ 10 phút chỉ chứa tối đa 1 lần. Với ngưỡng 5 lần/10 phút, nguồn này **không bao giờ bị ban**; dòng `Found 103.186.62.23` lúc 21:35:49 không kéo theo `Ban`. Ngược lại, tính theo cửa sổ 24 giờ thì nguồn này thử tới 15 lần (từ 10/09 16:33 đến 11/09 16:33). Một jail thứ hai với `findtime = 1d`, `maxretry = 5` sẽ bắt được nó trong vài giờ.

5.4. Đối chiếu kịch bản kiểm thử bắt buộc

Kịch bản	Kết quả	MC
Xác định đúng nguồn nổi bật từ log	**Đạt**: 103.186.62.23	02, 05, 06, 08
IP kiểm thử trong blacklist bị từ chối trên cổng SSH	**Chưa thực hiện**	–
<VPN_IP_CA_NHAN> vẫn truy cập sau blacklist và Fail2ban	**Chưa thực hiện**; chưa có `ignoreip`	–
Kiểm thử ban/unban trong phạm vi an toàn	**Đạt ở mức log**; chưa chứng minh chặn thực tế ở 24700	10
Sau reload/reboot vẫn hoạt động và có log	**Một phần**: có khôi phục ban khi khởi động lại jail; chưa reboot	10

6. Sự cố phát sinh, khoanh vùng và khắc phục

S1 – Jail Fail2ban áp cho cổng 22 trong khi SSH chạy cổng 24700	**Mức: Cao**
Phát hiện	`jail.local` đặt `port = ssh`; tên dịch vụ ssh trong `/etc/services` là 22/tcp. MC-01 cho thấy sshd chỉ nghe `0.0.0.0:24700` và `[::]:24700`.
Tác động	Action ban tạo rule chặn IP ở cổng đích 22. IP bị ban vẫn kết nối được tới 24700 và thử tiếp; Fail2ban ghi `Ban` nhưng thực tế gần như chỉ có tác dụng ghi log.
Khoanh vùng	Khi có IP đang bị ban, xem rule: `sudo nft list ruleset | grep -B2 -A6 f2b` (hoặc `sudo iptables -S | grep f2b`) và thử `ssh -p 24700` từ IP bị ban.
Khắc phục	Đổi thành `port = 24700`, chạy `sudo fail2ban-client reload sshd`, ban một IP test bằng `fail2ban-client set sshd banip <IP_TEST>`, sau đó kiểm tra rule và kết nối.
Trạng thái	**Chưa khắc phục**

S2 – Kiểm thử ban trên chính IP quản trị khi chưa có ignoreip	Mức: Trung bình
Phát hiện	113.23.44.41 là nguồn của phiên root đang mở (MC-01) và bị ban lúc 21:25:34 (MC-10). `jail.local` không có `ignoreip`.
Tác động	Nếu cổng trong jail đúng, phiên quản trị từ IP này có thể bị cắt trong 10 phút, chỉ còn cách vào qua console. Đề cũng yêu cầu `<VPN_IP_CA_NHAN>` vẫn truy cập được sau khi bật Fail2ban.
Khắc phục	Thêm `ignoreip = 127.0.0.1/8 ::1 <VPN_IP_CA_NHAN> <VPN_IP_GIANG_VIEN>`; kiểm thử ban bằng `banip` với IP test do giảng viên cấp; luôn giữ một phiên dự phòng.
Trạng thái	**Chưa khắc phục**

S3 – Dữ liệu thống kê bị nhiễm bởi chính lệnh điều tra	Mức: Trung bình
Phát hiện	MC-02 có dòng `2 COMMAND=/usr/bin/grep`; MC-03 trả về `5 \\K\\S+'` thay vì username.
Nguyên nhân	sudo ghi mỗi lệnh kèm tham số vào `auth.log`. Lệnh grep chứa đúng chuỗi đang tìm nên chính dòng log của nó cũng khớp. Phân tích trên log đang ghi thì mỗi lần chạy lại thêm dòng nhiễm.
Khắc phục	Thống kê IP chuyển sang regex `from \K[0-9.]+` (MC-08, đã áp dụng). Username cần lọc theo tiến trình: `grep 'sshd\[' auth.log | grep -oiP 'invalid user \K\S+'`. Về lâu dài, phân tích trên bản sao đã hash (mục 4.1).
Trạng thái	**Đã khắc phục cho IP; username chưa chạy lại**

S4 – Điều tra bằng root và phiên root console bỏ ngỏ	Mức: Trung bình
Phát hiện	Toàn bộ ảnh có dấu nhắc `root@maychucuavietanh`; `who` cho thấy root đăng nhập `tty1` từ 10/09 17:51, idle gần 17 giờ.
Tác động	Trái quy định 5 của đề; thao tác không đi qua sudo nên không truy vết theo người. Ai truy cập được console của nhà cung cấp là có ngay shell root.
Khắc phục	Đăng xuất phiên tty1 (hoặc đặt `TMOUT`); điều tra bằng `opsadmin` + sudo.
Trạng thái	**Chưa khắc phục**

7. Kết luận, blacklist và biện pháp phòng ngừa

7.1. Kết luận về dấu hiệu xâm nhập

Chưa phát hiện dấu hiệu xâm nhập ở mức kiểm tra cơ bản. Nguồn tấn công duy nhất được xác định (103.186.62.23) chưa có phiên thành công nào. Không có tiến trình, cổng nghe, kết nối hay service lạ. Các IP còn lại có thất bại đều theo hình thái gõ sai rồi đăng nhập thành công.

Có hoạt động tấn công: 103.186.62.23 dò mật khẩu root theo kiểu chậm và bền bỉ trong ít nhất 4 ngày, và cấu hình Fail2ban hiện tại không chặn được nó.

Chưa thể khẳng định chắc chắn “không bị xâm nhập” vì ba lý do: 7 IP có phiên root thành công chưa được xác nhận chủ sở hữu, nội dung cron chưa được kiểm tra, và root vẫn đăng nhập bằng mật khẩu từ Internet.

7.2. Bảng blacklist cuối cùng

IP	Lý do	Cơ chế	Thời hạn đề xuất	Trạng thái
103.186.62.23	33 lần thất bại, chỉ nhắm root, 0 phiên thành công, dò chậm kéo dài	`ufw insert 1 deny from` và jail dài hạn	30 ngày, rà soát lại; vĩnh viễn nếu tái diễn	**Đề xuất, chưa áp dụng**
<IP_KIEM_THU>	IP test do giảng viên cấp cho kịch bản kiểm thử	`ufw insert 1 deny from`	Trong buổi nghiệm thu	**Chưa được cấp**
Theo dõi, chưa chặn	172.216.245.31 và 7 IP chưa xác định ở mục 4.6	Rà soát `last` định kỳ	Chặn nếu không xác nhận được chủ sở hữu	**Chờ xác nhận**

Rule blacklist được chèn ở vị trí 1 (`insert 1`) để đứng trước mọi rule allow, và không chạm tới rule whitelist VPN của Bài 2.

7.3. Biện pháp phòng ngừa

Mức hệ thống, sắp xếp theo mức ưu tiên:

- Sửa jail: `port = 24700`, thêm `ignoreip` cho IP VPN; tăng `bantime` lên 1h khi hết giai đoạn lab.
- Thêm jail bắt dò chậm, ví dụ `findtime = 1d`, `maxretry = 5`, `bantime = 1w`. Với dữ liệu thực tế, 103.186.62.23 sẽ bị chặn trong vài giờ.
- Chỉ cho SSH từ whitelist VPN (Bài 2). Đây là biện pháp loại bỏ gốc rễ: cổng 24700 không còn mở ra Internet thì không nguồn dò nào chạm tới được.
- `PermitRootLogin no` và `PasswordAuthentication no`, chuyển sang SSH key cho tài khoản cá nhân. 82/83 lần thất bại qua SSH đều nhắm root bằng mật khẩu.
- Đăng xuất phiên root tty1, đặt `TMOUT`; gỡ các service không cần (`ModemManager`, `udisks2`, `upower`).

Mức quy trình:

- Bảo toàn log (sao chép và hash) trước mọi thay đổi; phân tích trên bản sao.
- Thống kê theo tiến trình `sshd` để tránh lẫn log của người điều tra.
- Lập sổ đăng ký IP quản trị có chủ sở hữu; rà soát `last` hằng tuần để phát hiện nguồn không có trong sổ.
- Kiểm thử ban bằng IP test và `banip`, không dùng IP quản trị; luôn giữ phiên dự phòng.
- Quản trị qua `opsadmin` + `sudo` để mọi thao tác được ghi theo người.

7.4. Hạng mục chưa hoàn tất

- Sao lưu auth.log, btmp, wtmp kèm `SHA256SUMS` (checklist 05).
- Chạy lại thống kê username không tồn tại có lọc sshd (09).
- Xác nhận chủ sở hữu 7 IP có phiên root và hoạt động console ngày 10/09 (11).
- Kiểm tra `crontab -l` của root và các user, `/etc/cron.d`, `/etc/cron.daily` (15).
- Áp dụng blacklist 103.186.62.23 và IP test; chứng minh bị từ chối ở cổng SSH, VPN cá nhân vẫn vào được (18, 26, 27).
- Sửa S1, S2, rồi chứng minh IP bị ban thực sự không kết nối được tới 24700 (20, 22).
- Reboot server, thu `systemctl is-enabled fail2ban` và `fail2ban-client status sshd` sau reboot (25).

Phụ lục – Danh mục minh chứng

Mã	File trong 05_Minh_chung/	Nội dung
MC-01	`MC-01_hien_trang_16h26.png`	date, who, w, ss -tunap
MC-02	`MC-02_top_ip_awk_bi_nhiem.png`	Top IP thất bại (awk), có dòng nhiễm
MC-03	`MC-03_truy_van_username_khong_hop_le.png`	Truy vấn username bị nhiễm
MC-04	`MC-04_last_dang_nhap_thanh_cong.png`	last
MC-05	`MC-05_lastb_phan_1.png`	lastb phần 1
MC-06	`MC-06_lastb_phan_2.png`	lastb phần 2
MC-07	`MC-07_process_port_service.png`	ps, ss -tuln, service đang chạy
MC-08	`MC-08_top_ip_regex_va_accepted.png`	Top IP (regex) và đối chiếu Accepted
MC-09	`MC-09_fail2ban_status_ban_dau.png`	fail2ban-client status
MC-10	`MC-10_fail2ban_log_ban_unban.png`	fail2ban.log: Ban / Unban / Restore